

DevTrack - Auditoria de Segurança e Sustentabilidade

Relatório atualizado após correções do ciclo "Agora".

Data de atualização: 20/05/2026.

Este documento continua sendo um direcionador técnico. A palavra final sempre é sua.

1. Estado Atual

O ciclo "Agora" avançou bastante. Foram corrigidos os logs sensíveis, validação do login, validação forte de senha no back-end, tratamento global de erros, rota pública antiga, limpeza de sessão no 401, lint do front, logs do front e leitura do novo padrão de erro da API.

O `application.properties` permanece hardcoded por decisão de roadmap, já que a troca de banco está planejada. Isso fica marcado como risco aceito/adiante, não como esquecimento.

2. Checklist "Agora" Atualizado

STATUS	ITEM	ARQUIVOS RELACIONADOS	OBSERVAÇÃO
Feito	Remover logs sensíveis de back-end	<code>UserService.java</code>	Removidos logs de senha, hash e token.
Adiado	Remover secrets do arquivo de config	<code>application.properties</code>	Risco aceito por enquanto; proteger quando trocar/configurar o banco definitivo.
Feito	Adicionar validação no login	<code>LoginRequestDTO.java</code> , <code>UserController.java</code>	Adicionados <code>@Valid</code> , <code>@NotBlank</code> , <code>@Email</code> e <code>@Size</code> .
Feito	Repetir validação forte de senha no backend	<code>UserRequestDTO.java</code> , <code>UserPasswordUpdateRequestDTO.java</code>	Back-end agora exige maiúscula, minúscula, número e símbolo.
Feito	Criar handler global de erros	<code>ApiErrorResponse.java</code> , <code>GlobalExceptionHandler.java</code>	API agora retorna <code>message</code> e, em validação, <code>fieldErrors</code> .
Feito	Proteger/remover rota /dashboard	<code>AppRoutes.jsx</code>	A rota antiga agora passa por <code>PrivateRoute</code> e redireciona para <code>/dashboard22</code> .
Feito	Corrigir limpeza de sessão no 401	<code>api.js</code> , <code>tokenService.js</code>	Interceptor chama <code>logout()</code> e redireciona para login.
Feito	Corrigir lint e função morta	<code>validator.js</code> , <code>Profile.jsx</code>	Removida função morta e movido <code>GitHubIcon</code> para fora do render.
Feito	Remover logs do front	<code>ProfileEdit22.jsx</code>	Removidos <code>console.log</code> de update de usuário.
Feito	Checar impacto de novo handler no front	<code>apiError.js</code> , <code>Login.jsx</code> , <code>Register.jsx</code> , <code>ProfileEdit22.jsx</code> , <code>Dashboard22.jsx</code>	Front agora lê <code>message</code> e concatena <code>fieldErrors</code> quando existirem.

3. Back-end - Situação Atual

GRAVIDADE ORIGINAL	PROBLEMA	STATUS	ARQUIVOS	RESULTADO
Crítica	Loga console em autenticação	Feito	UserService.java	Senhas, hash e token não são mais impressos no console.
Crítica	Secrets hardcoded	Adiado por decisão	application.properties	Será protegido quando a configuração definitiva do banco for definida.
Alta	Login sem validação Jakarta	Feito	LoginRequestDTO.java , UserController.java	Payload inválido é barrado antes do service.
Alta	Senha forte somente no front-end	Feito	UserRequestDTO.java , UserPasswordUpdateRequestDTO.java	API não aceita mais senha fraca por chamada direta.
Alta	Ausência de tratamento global de erros	Feito	GlobalExceptionHandler.java , ApiErrorResponse.java	Erros de validação, duplicidade e runtime têm formato previsível.
Alta	Login sem rate limit	Pendente	UserController.java , camada futura de rate limit	Continua como próximo hardening antes de produção.
Média	JWT usa email como subject	Pendente para depois do MVP	JwtService.java , JwtAuthenticationFilter.java	Ainda é uma dívida técnica conhecida.

4. Front-end - Situação Atual

GRAVIDADE ORIGINAL	PROBLEMA	STATUS	ARQUIVOS	RESULTADO
Média	Rota /dashboard pública	Feito	AppRoutes.jsx	Agora exige autenticação e redireciona para a dashboard atual.
Média	401 remove só token	Feito	api.js , tokenService.js	Agora limpa token e usuário via logout() .
Baixa	Função morta em validator.js	Feito	validator.js	Lint não acusa mais variáveis inexistentes nesse arquivo.
Baixa	GitHubIcon - criado dentro do render	Feito	Profile.jsx	Componente movido para escopo de módulo.
Baixa	Logo no update de perfil	Feito	ProfileEdit22.jsx	Removidos logs de dados de usuário.
Média	Formulários não liam fieldErrors	Feito	apiError.js e telas com requests	Mensagens do novo handler global aparecem melhor no front.
Alta	JWT em localStorage	Pendente antes de produção	tokenService.js	Risco aceito no MVP; migrar para cookie HttpOnly ou reforçar CSP antes de produção.

5. Próximo Caminho Recomendado

ORDEM	PRÓXIMO PASSO	ARQUIVOS	MOTIVO
1	Testar fluxo completo manualmente	Registro, login, perfil, update senha, delete conta	Confirmar que o novo handler não mudou a UX de erro de forma indesejada.
2	Resolver Maven Wrapper ou instalar Maven global	<code>mvnw.cmd</code> , ambiente local	Sem isso, não dá para validar o back-end por teste automatizado neste ambiente.
3	Adicionar rate limit no login	<code>UserController.java</code> ou filtro/interceptor dedicado	Próximo item de segurança relevante antes de produção.
4	Criar <code>/user/me</code>	<code>UserController.java</code> , <code>UserService.java</code> , <code>userService.js</code>	Reduz dependência do usuário salvo em <code>localStorage</code> .
5	Planejar troca do DB e proteção de secrets	<code>application.properties</code> , <code>profiles/env vars</code>	Fechar o risco aceito quando a decisão de banco estiver madura.

6. Validações Executadas

COMANDO	RESULTADO
<code>npm run lint</code>	Passou
<code>npm run build</code>	Passou
<code>cmd /c mvnw.cmd test</code>	Ainda bloqueado pelo Maven Wrapper local: <code>Cannot start maven from wrapper</code> .